Building Secure Systems? Authentication, Access Control, and the Human Element in the 2021 Colonial Pipeline Ransomware Attack

Surafel Melese Tariku

School of Cyber Studies, The University of Tulsa

CYB-7153-01: Foundations of Cyber Security

Prof. Jackie Wyatt

Sep 20, 2027

Building Secure Systems? Authentication, Access Control, and the Human Element in the 2021 Colonial Pipeline Ransomware Attack

Introduction

On May 7, 2021, the Colonial Pipeline Company found that criminals had attacked its computer network with ransomware. Within hours, the company shut down its whole pipeline system. This system supplies about half of the fuel used on the East Coast of the United States (Gatlan, 2021). For almost six days, fuel could not move from refineries on the Gulf Coast to markets in the Southeast. Thousands of gas stations ran out of fuel. Drivers waited in long lines, and prices went up (Kelly & Resnick-Ault, 2021). The company also paid a ransom worth about $4.4 million (Gatlan, 2021).

The attack is important because it was simple, not because it was advanced. The attackers entered the network with one password. It belonged to an old virtual private network (VPN) account. This account did not use multi-factor authentication, or MFA (Kelly & Resnick-Ault, 2021). MFA means that a user must prove identity in two ways, for example with a password and a code from a phone.

This paper studies the attack with the main ideas from the first three modules of this course. The first idea is the CIA triad and access control. The second is identification, authentication, and authorization. The third is the human side of security, which includes economics, psychology, and decision-making. The argument of this paper is that the attack was a chain of small failures. One technical gap existed because of human and organizational choices. The damage grew because the company could not work without its business computer systems. In the end, most of the costs were paid by other people.

Background

The Company and Its Systems

Colonial Pipeline Company runs the largest fuel pipeline in the United States. It carries about 2.5 million barrels of gasoline, diesel, and jet fuel every day from the Gulf Coast to the East Coast (Lubin, 2023). Many states in the Southeast have few other ways to receive fuel. For this reason, the pipeline is a clear example of critical infrastructure.

Colonial uses two kinds of computer systems. The information technology network, or IT network, supports business work such as email, accounting, and billing. The operational technology network, or OT network, controls the pumps and valves that move the fuel. The ransomware was placed on the IT network. Two federal agencies reported no sign that the OT network was directly affected. These agencies were the Cybersecurity and Infrastructure Security Agency, called CISA, and the Federal Bureau of Investigation, or FBI (CISA & FBI, 2021). However, the billing system was attacked. Without it, the company could not follow deliveries or send bills to customers. This problem was one reason for the decision to stop the pipeline (Lubin, 2023).

The Attackers and the Rules Before the Attack

The FBI said that the attack came from DarkSide, a criminal group based in Russia (Kelly & Resnick-Ault, 2021). DarkSide worked as a ransomware service. One group built the ransomware and rented it to other criminals. Those criminals broke into networks and shared the money with the developers (Lubin, 2023). This model makes ransomware easy to spread. Before May 2021, federal cybersecurity rules for pipelines were voluntary. The Transportation Security Administration gave advice, but it did not require companies to follow it (Lubin, 2023). This gap in the rules helped to decide how much security operators chose to buy.

Technical Analysis

How the Attackers Got In

Investigators found that the attackers first logged in on April 29, 2021. They used a VPN account that nobody used anymore. The account had never been turned off. Later, the password was found in a list of stolen passwords on the dark web. This suggests that someone had used the same password on another website, and that website was hacked (Turton & Mehrotra, 2021).

In his Senate testimony, the chief executive officer said that this old VPN had only single-factor authentication. He also said that the password was complex and hard to guess (Kelly & Resnick-Ault, 2021). So the attackers did not use a software bug. They did not need one. For the system, they looked like a normal user with a correct username and password.

What the Attackers Did Next

After they got in, the attackers prepared a double attack. On May 6, they stole about 100 GB of data in about two hours. On May 7, they encrypted the files with the DarkSide ransomware (Gatlan, 2021). The ransomware used two encryption methods together. A fast method locked the files, and a second method protected the keys. Because of this design, the victim cannot open the files without the key of the attackers. The criminals also said that they would publish the stolen data. In this way, they put pressure on the company twice. CISA and the FBI reported that DarkSide criminals often used special tools to control the systems they attacked and to hide their internet traffic (CISA & FBI, 2021).

Impact on the CIA Triad

The CIA triad from Module 1 explains the damage well. Confidentiality was lost because data was stolen. This data included personal information about 5,810 people (Gatlan, 2021). Integrity was damaged because files were encrypted. The company could no longer trust its

systems or its billing records. Availability was the biggest loss. First the IT systems stopped, and then the pipeline stopped. The ransomware never stopped the pumps, but the fuel stopped anyway. This shows that a wall between IT and OT is useful but not enough. Business processes still depend on IT systems (Lubin, 2023).

Controls That Were Missing

Some controls were in place. The VPN encrypted the connection, and the password followed complexity rules. The OT network does not seem to have been infected. However, the most important control was missing. CISA and the FBI say that companies should require MFA for remote access to IT and OT networks (CISA & FBI, 2021). With a second factor, such as a code from a phone, the stolen password alone would not have worked.

Account management was a second problem. An account that nobody uses should be turned off at once. This rule follows the idea of least privilege, which means that users get only the access they really need. Detection was a third problem. A transfer of 100 GB of data in two hours is not normal, and it could have started an alarm. Other measures would have reduced the damage after the attackers were already inside. These measures include a stronger separation of IT and OT, backups that are tested and kept offline, and regular practice of manual controls (CISA & FBI, 2021). Researchers who studied this case also recommend a zero-trust model. In this model, no user and no device is trusted automatically, even inside the network (Beerman et al., 2023).

Human Factors

Human Error and Psychology

The human error in this case was organizational, not individual. There is no public proof that an employee was tricked by a phishing email. Instead, an account stayed active after it was

no longer needed. The company also allowed remote access without MFA (Turton & Mehrotra, 2021). Social engineering is still possible, because DarkSide criminals used phishing in other attacks. CISA and the FBI advised training and phishing tests for this reason (CISA & FBI, 2021). Even so, the attackers did not need to trick anyone on the day of the attack. They only needed a secret that had already leaked.

Some psychological factors help to explain the problem. People have many accounts, so they reuse passwords. Following security advice costs time and effort, and the benefit is hard to see. The focus on password complexity also shows a common mistake. A complex password stops guessing, but it protects nothing after the password is stolen. In addition, a forgotten account causes no daily trouble. Nobody feels a reason to remove it. People also tend to believe that serious events will not happen to them. This belief makes it easy to delay security work.

Psychology was also important during the crisis. The company decided to pay the ransom very fast, under stress and with little information. Later, some senators asked why the company did not speak to the government first (Kelly & Resnick-Ault, 2021).

Effects on People and Society

Fear of shortages caused panic buying, and this made the shortages worse (Kelly & Resnick-Ault, 2021). The privacy harm was also real. The stolen records included names, dates of birth, Social Security numbers, driver's license numbers, and health insurance information. The people involved were informed only in August 2021 (Gatlan, 2021). A federal emergency declaration for 17 states and the District of Columbia made it easier to move fuel by truck (Gatlan, 2021). Even so, many people could not get to work or run their business in a normal way. Public trust in critical infrastructure was damaged.

Economic Impact

Colonial paid several direct costs. The ransom was about $4.4 million (Gatlan, 2021). The company also paid for the response to the incident, for repairs, for lawyers, and for credit monitoring for the people whose data was stolen. It lost income while the pipeline was closed. The pipeline normally carries about 2.5 million barrels per day (Lubin, 2023). A closure of almost six days therefore delayed around 15 million barrels of deliveries. About one month later, the U.S. Department of Justice took back 63.7 bitcoin from the attackers. This was most of the payment, but it was worth only about $2.3 million, because the price of bitcoin had fallen (U.S. Department of Justice, 2021). One year later, regulators proposed a fine of $986,400 for weak planning of manual operations (Lakshmanan, 2022).

The indirect costs were larger, and other people paid them. Gas stations lost sales. Consumers paid higher prices and waited in long lines. Companies that need fuel had to change their work (Kelly & Resnick-Ault, 2021). The ransom payment also had an effect on crime. It gave money to the criminals and created a reason for similar attacks (Beerman et al., 2023). The government response made the attack more expensive for the criminals. The Department of Justice said that its goal was to make such attacks less profitable (U.S. Department of Justice, 2021). DarkSide closed soon after the attack, and the next group of the same criminals said that it would avoid oil and gas targets (Gatlan, 2021).

Module 3 explains this pattern. MFA and account reviews are cheap when we compare them with a regional fuel crisis. Howver, Colonial did not pay most of the cost of the failure. The cost went to millions of drivers, to thousands of businesses, and to the government. Economists call this a negative externality. It means that the company that can prevent the harm does not pay

for it. For this reason, companies often spend less on security than society needs. This is one of the strongest arguments for mandatory rules in critical infrastructure (Lubin, 2023).

Legal and Ethical Considerations

Laws and Official Responses

Several laws and rules applied to this case. Before the attack, the Transportation Security Administration was responsible for pipeline security, but it only published voluntary guidelines (Lubin, 2023). State breach notification laws applied to the stolen personal data (Gatlan, 2021). The actions of the attackers were federal crimes, such as computer intrusion and money laundering. These crimes gave the government the legal basis to act against the ransom money (U.S. Department of Justice, 2021).

The response was fast. Colonial told the FBI about the attack very early. Investigators then followed the payment on the public Bitcoin record. They found a wallet, and the FBI had the private key for it. With a court warrant, the government took the money back (U.S. Department of Justice, 2021). After the attack, the federal government published the first mandatory cybersecurity directives for pipeline operators. These rules require incident reporting, a cybersecurity coordinator, and specific protection measures. Congress later made reporting rules for critical infrastructure stronger (Lubin, 2023). Regulators also found that Colonial had not planned well for a manual shutdown and restart. This weakness made the national impact worse (Lakshmanan, 2022).

Ethical Questions

The criminals carry the main responsibility. However, a company that runs critical infrastructure also has a strong duty to the public. People depend on its service and cannot

choose another supplier. A company can follow the law and still fail this duty, because the rules were voluntary at that time (Lubin, 2023).

The ransom payment is a difficult ethical question. If we look at the results, paying can be right, because it may bring the fuel back faster and reduce harm to millions of people. If we look at the rule, paying is wrong, because it gives money to criminals and encourages new attacks on other victims (Beerman et al., 2023). The shutdown raises a similar question. The company could not send bills, and this reason stood next to real safety concerns (Lubin, 2023). Honesty is another issue. The people whose data was stolen learned about it only months later (Gatlan, 2021).

Lessons Learned

Module 1 shows why availability is so important in critical infrastructure. It also shows that access control must cover every door into the network, including old ones. Least privilege and safe default settings mean that access should be removed as soon as it is not needed. Organizations must also understand how OT depends on IT. They must plan how to keep key functions running when IT systems are down (CISA & FBI, 2021).

Module 2 is central, because this was a failure of identity. Identification means that every account has a known owner and a clear purpose. Regular reviews can find accounts that nobody uses. Authentication needs more than a complex password. A password is only something the user knows, and it proves nothing after it leaks. A second factor is therefore necessary for remote access (CISA & FBI, 2021). Authorization means that a remote account should reach only a small part of the network. Logging and monitoring complete the picture, because they support accountability and help to find strange behavior.

Module 3 explains the human and economic causes. Security controls should fit real human behavior. For example, companies can use single sign-on with MFA or password managers. Then users do not need to remember many complex passwords. Regulation helps when the costs of a failure fall on other people (Lubin, 2023). Hard decisions also need preparation. A company should decide in advance how it will react to a ransom demand or a shutdown. Weak planning for manual operations made this outage longer (Lakshmanan, 2022). Fast contact with the police made the partial recovery of the money possible (U.S. Department of Justice, 2021).

Conclusion

The Colonial Pipeline attack started with a forgotten VPN account. The account was protected only by a password that had already leaked. MFA was missing, and nobody had turned the account off. For these reasons, the criminals entered the network, stole data, and started the ransomware. The technical damage stayed on the IT network. However, the company depended on these systems and was not ready for manual operations. An IT incident therefore became a regional fuel crisis.

This case cannot be explained by technology alone. Access control and the CIA triad show what was lost. Identification, authentication, and authorization show how the attackers got in. The human side of security shows why simple protections were missing and why the harm spread so far. The attack also changed policy, because it led to the first mandatory cybersecurity rules for pipelines in the United States. The clearest message is simple. The most dangerous weaknesses are often not complex technical problems. They are small gaps that stay open because of human, organizational, and economic reasons.

References

Beerman, J., Berent, D., Falter, Z., & Bhunia, S. (2023). A review of Colonial Pipeline ransomware attack. In *2023 IEEE/ACM 23rd International Symposium on Cluster, Cloud and Internet Computing Workshops (CCGridW)* (pp. 8–15). IEEE. https://doi.org/10.1109/CCGridW59191.2023.00017

Cybersecurity and Infrastructure Security Agency & Federal Bureau of Investigation. (2021, May 11). *DarkSide ransomware: Best practices for preventing business disruption from ransomware attacks* (Joint Cybersecurity Advisory AA21-131A). https://www.cisa.gov/news-events/cybersecurity-advisories/aa21-131a

Gatlan, S. (2021, August 16). Colonial Pipeline reports data breach after May ransomware attack. *BleepingComputer*. https://www.bleepingcomputer.com/news/security/colonial-pipeline-reports-data-breach-after-may-ransomware-attack/

Kelly, S., & Resnick-Ault, J. (2021, June 9). Hackers only needed a single password to disrupt Colonial Pipeline, CEO testifies. *Insurance Journal*. https://www.insurancejournal.com/news/national/2021/06/09/617870.htm

Lakshmanan, R. (2022, May 10). U.S. proposes $1 million fine on Colonial Pipeline for safety violations after cyberattack. *The Hacker News*. https://thehackernews.com/2022/05/us-proposes-1-million-fine-on-colonial.html

Lubin, A. (2023). Cyber plungers: Colonial Pipeline and the case for an omnibus cybersecurity legislation. *Georgia Law Review, 57*(4), Article 4. https://digitalcommons.law.uga.edu/glr/vol57/iss4/4

Turton, W., & Mehrotra, K. (2021, June 4). Hackers breached Colonial Pipeline using compromised password. *Bloomberg*. https://www.bloomberg.com/news/articles/2021-06-04/hackers-breached-colonial-pipeline-using-compromised-password

U.S. Department of Justice. (2021, June 7). *Department of Justice seizes $2.3 million in cryptocurrency paid to the ransomware extortionists Darkside*. https://www.justice.gov/archives/opa/pr/department-justice-seizes-23-million-cryptocurrency-paid-ransomware-extortionists-darkside

Claude Opus 5 (Anthropic, 2026) was used to draft an initial version of the conclusion, which the author revised.